WORKSHOP NATIONAL BAC+5 · EPSI · OCTOBRE 2026

Une plateforme de paiement qui se répare seule

Attaque réelle · détection par Machine Learning · remédiation Zero-Touch · preuve par une transaction réussie.



Consortium Groupe 12 — Ibrahima DIENG · Simon Junior POUT · Babacar ANE · Richard Cédric YAO · Yasmine Adouni Olaïdé DJINADOU

Sommaire

47 s

pour que le virement redevienne utilisable sous attaque, sans aucune intervention humaine

01 L'enjeu

02 La solution

03 Les résultats

04 La gouvernance

05 La démonstration

01

L'enjeu

Un paiement qui s'arrête coûte à chaque minute.

Une reprise manuelle ne suffit plus

Aujourd'hui chaque incident de paiement est réparé à la main : lent, peu reproductible, coûteux pour les partenaires. Objectif : une chaîne de résilience observable et vérifiable.

01

Collecter

Prometheus relève les métriques, Loki les journaux

02

Détecter

un modèle ML repère l'écart au trafic normal

03

Décider

une table de décision choisit l'action

04

Agir

des playbooks Ansible bannissent et redémarrent

05

Prouver

une vraie transaction valide la reprise

→ ***Aucune intervention humaine entre l'attaque et la preuve de reprise.***

L'incident : un déni de service applicatif

40 s
durée de l'attaque

60
connexions simultanées

1 PC
distinct via le WAF

La latence et le CPU explosent
chaque requête porte un jeton invalide : payment-api doit interroger auth

Crédible
le trafic traverse le WAF, qui ne bloque que les charges malveillantes

Reproductible
paramètres fixes, rejoué dix fois

Disponibilité ≠ compromission

DoS : reprise automatique

SQLi / XSS : prévention, WAF 403

Brute force : 429 + alerte SOC

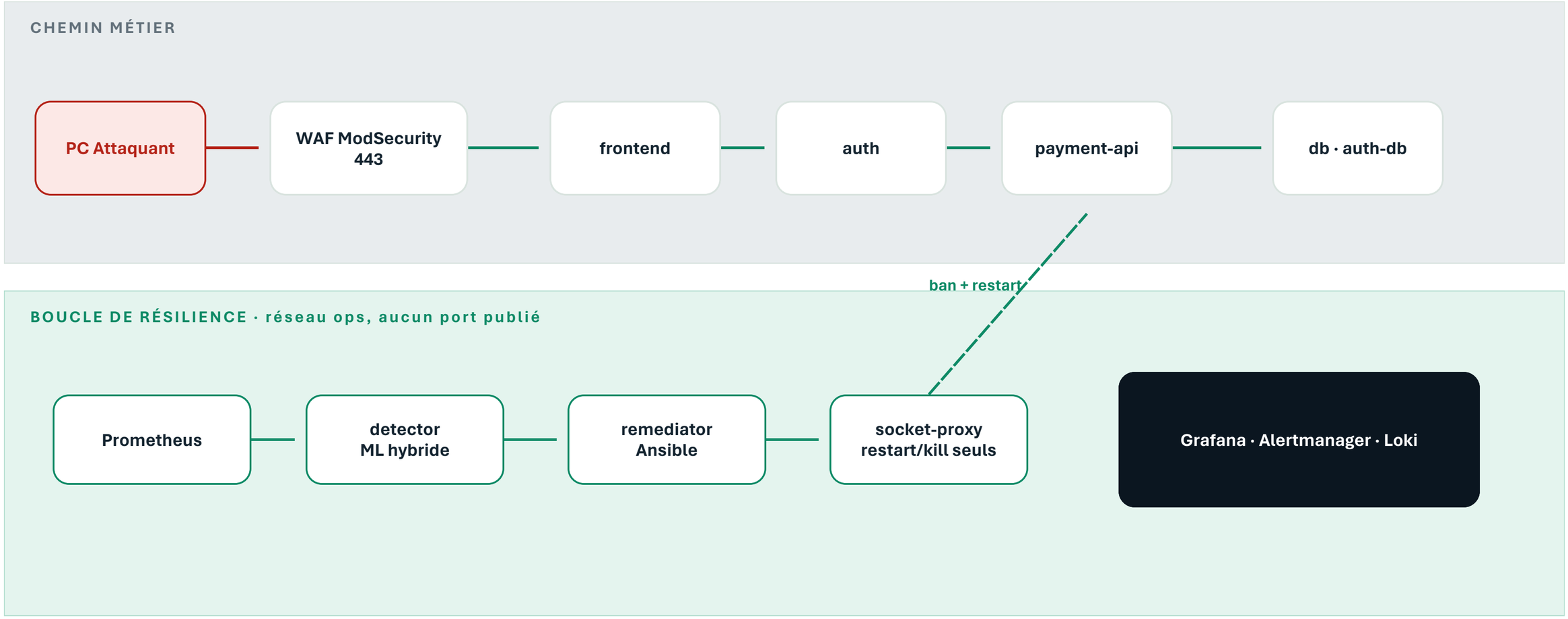
Redémarrer ne corrige pas une fuite : pour une compromission, on prévient, on trace et on investigue.

02

La solution

Un SI de paiement fictif qui se surveille et se répare.

Un point d'entrée, cinq réseaux cloisonnés



Une détection apprise, pas codée en dur

8 indicateurs de payment-api

req/s, erreurs 5xx, latence p95, CPU, RAM, requêtes SQL… lus dans Prometheus

Appris sur le trafic normal

25 minutes de trafic opérateur simulé, soit 151 échantillons

Modèle hybride

Isolation Forest + enveloppe statistique : l'Isolation Forest seul saturait à 0,506

Décision explicable

chaque alerte cite les trois indicateurs les plus anormaux

0,608

seuil calibré sur le trafic normal

0,972

score d'anomalie dès environ 14 requêtes par seconde

7 ms

entre l'alerte du detector et le remediator

Remédiation Zero-Touch, preuve à l'appui

1 **detected**
alerte detector / Alertmanager

2 **ban**
signature Loki → WAF

3 **restart**
Ansible si besoin

4 **preuve**
transaction = 200 + /health

5 **recovered**
journalisé · interface · Grafana

Un moteur puissant, mais bridé

Jamais de socket Docker brut · proxy limité à restart/kill · aucun port publié · escalade vers l'opérateur en cas d'échec.

Défense en profondeur et fonction SOC

01 WAF

ModSecurity + OWASP CRS en mode blocage : SQLi et XSS rejetées en 403

02 SOC Grafana

échecs de connexion, injections bloquées, remédiations et chronologie

03 Secrets

SOPS + age : aucun secret en clair dans le dépôt Git

04 Cloisonnement

auth hors du réseau des paiements, bases sans port publié

05 Durcissement

lecture seule, cap_drop ALL, non-root, images épinglées

06 Moindre privilège

rôles SQL limités, journal en ajout seul, assistant RAG sans droit

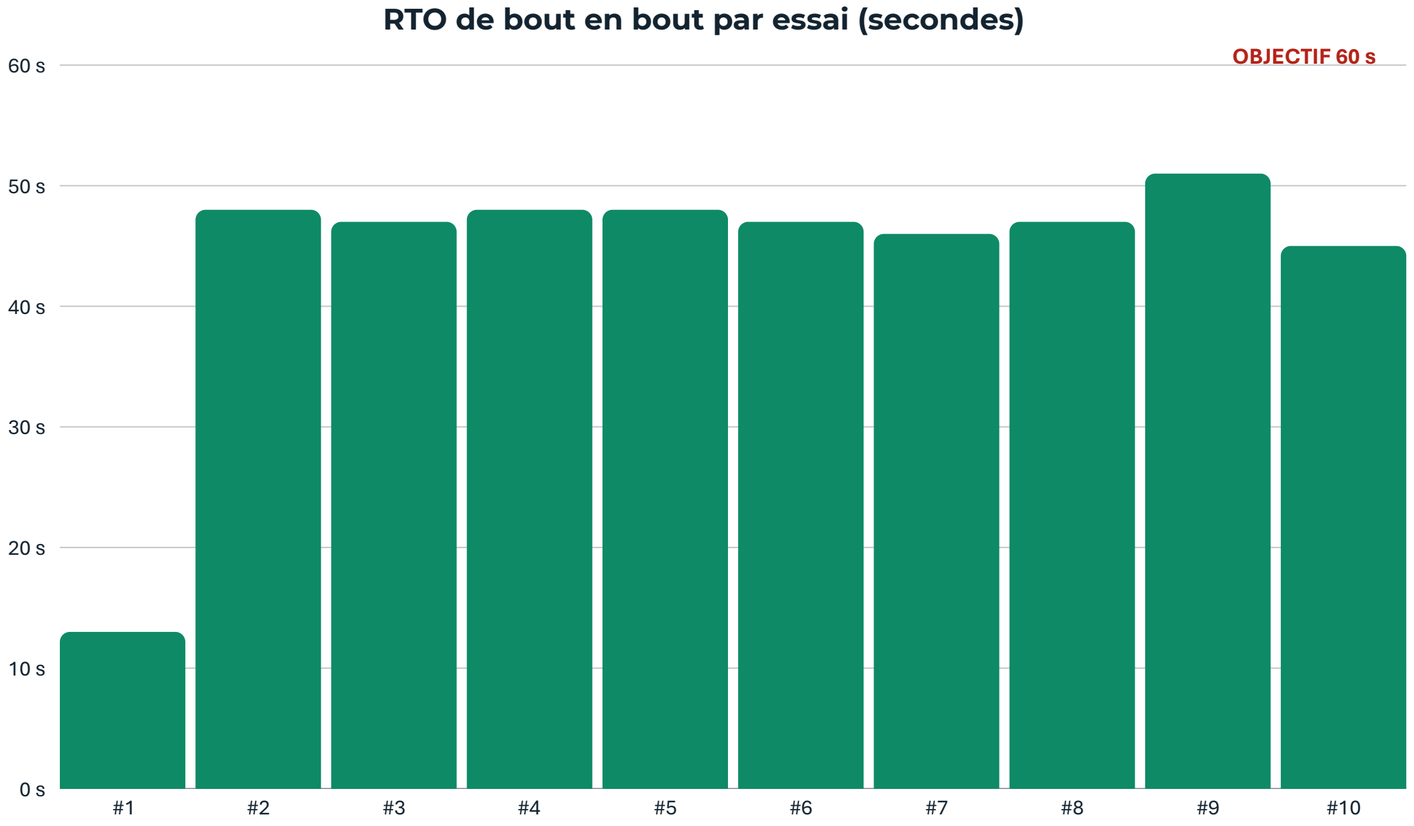
Une plateforme qui se défend ne doit pas ouvrir de nouvelle porte pour le faire.

03

Les résultats

Mesurés, rejoués, sans intervention humaine.

10 reprises autonomes sur 10



10/10
reprises sans intervention humaine

47 s
RTO médian · 13 à 51 s

74
tests unitaires sur 5 microservices

L'essentiel du RTO est la détection (fenêtre d'une minute), fiabilité préférée à la vitesse.

04

La gouvernance

Des choix justifiés par le risque, des limites assumées.

Des choix justifiés par le risque

EBIOS RM — Critique

Gravité du DoS sur le paiement.

Cinq ateliers menés sur l'architecture livrée.

PCA/PRA

RTO < 60 s · RPO ≈ 0

Quatre scénarios couverts.

NIS2 / DORA

DORA en priorité pour la finance. Le prototype démontre la résilience technique, pas la notification ni le TLPT.

Recommandation à la direction : industrialiser les sauvegardes et tester la restauration, puis MFA et CI de sécurité.

Limites assumées et suite industrielle

LIMITE DU DÉMONSTRATEUR		EN CONTEXTE INDUSTRIEL
IP source masquée par Docker Desktop	→	**Bannissement par IP et réputation**
Modèle appris sur 25 min de trafic simulé	→	**Historique réel, jeu de validation distinct**
Détection en 20 à 40 s (fenêtre d'une minute)	→	**Fenêtres courte et longue combinées**
Restauration en squelette, mono-poste	→	**Sauvegardes testées, Kubernetes, base en HA**

Ces limites sont documentées dans le dépôt : chacune peut être vérifiée par le jury.

Place à la démonstration

Attaque
depuis le PC Attaquant

Détection
anomalie expliquée

Remédiation
automatique

Preuve
transaction réussie

L'ÉQUIPE

ID Ibrahima DIENG · SP Simon Junior POUT · BA Babacar ANE
RY Richard Cédric YAO · YD Yasmine Adouni Olaïdé DJINADOU

Merci — vos questions sont les bienvenues.